Course Overview

Introduction to Computer Security

Prese. By: Tagel W.

Contents

Introduction to Computer Security

- Basic Concepts of Computer Security
- Threats, Vulnerabilities, Controls, Risk
- Goals of Computer Security
- Security Attack
- Security Policies and Mechanisms
- Prevention, Detection, and Deterrence
- Software Security Assurance

What is Computer Security?

- Computer security refers to the protection of computer systems, networks, and data from unauthorized access, theft, damage, and other malicious activities.
- It encompasses various technologies, processes, and practices to reduce the risks of cyber attacks, data breaches, and other security threats.
- Computer security aims to safeguard the confidentiality, integrity, and availability of information stored, processed, and transmitted by computers and computer networks.

Cont…

- **Computer Security** refers to techniques for ensuring that data stored in a computer cannot be read or compromised by any individuals without authorization.
- It also the provisions and policies adopted to protect information and property from theft, corruption, or natural disaster while allowing the information and property to remain accessible and productive to its intended users.

Cybercriminal Reports

- Cybercrime is predicted to cost the world $8 trillion USD in 2023, according to Cyber security Ventures.
- If it were measured as a country, then cybercrime would be the world's third largest economy after the U.S. and China.
- We expect global cybercrime damage costs to grow by 15 percent per year over the next three years, reaching $10.5 trillion USD annually by 2025, up from $3 trillion USD in 2015.

Cont…

- Our report provides a breakdown of the cybercrime damage costs predicted in 2023:

  - ✓ $8 trillion USD a Year.
  - ✓ $667 billion a Month.
  - ✓ $154 billion a Week.
  - ✓ $21.9 billion a Day.
  - ✓ $913 million an Hour.
  - ✓ $15.2 million a Minute.
  - ✓ $255,000 a Second.

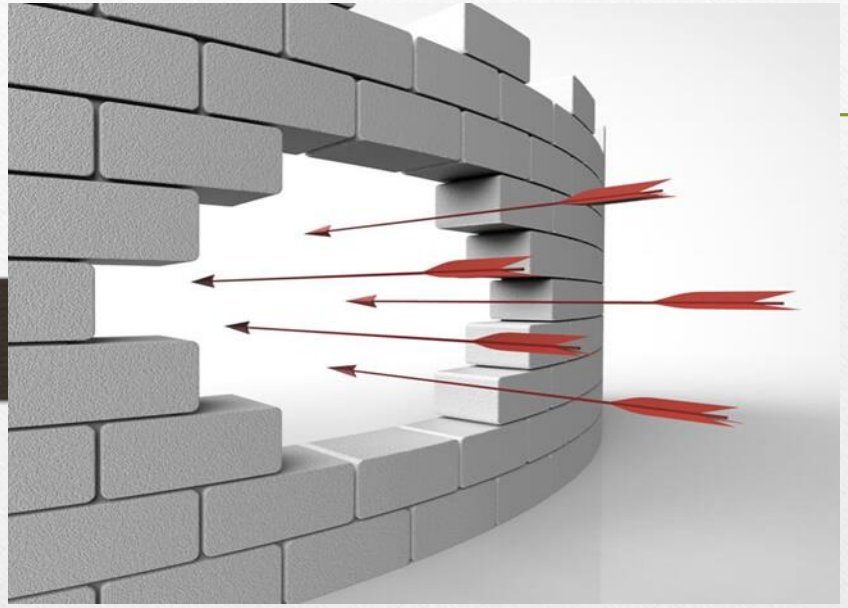
Threats, Vulnerabilities and Controls

* **Vulnerabilities:** A weakness in the organization, computer system, or network that can be exploited by threat.
* **Threats:** Something that can potentially cause damage to information assets.
* **Control:** an action, device, procedure, or technique that remove or reduce a vulnerabilities.

Vulnerabilities in Security

- In information security, a vulnerability is a weakness which can be exploited by a threat actor, such as an attacker, to cross privilege boundaries within a computer system.
- In cyber-security, a vulnerability is a weakness that can be exploited by cybercriminals to gain unauthorized access to a computer system.
- After exploiting a vulnerability, a cyber-attack can run malicious code, install malware and even steal sensitive data.

Vulnerabilities…..





Common Security Vulnerabilities

- **Broken Authentication:** When authentication credentials are compromised, user sessions and identities can be hijacked by malicious actors to pose as the original user.
- **SQL Injection:** As one of the most prevalent security vulnerabilities, SQL injections attempt to gain access to database content via malicious code injection.
- **Cross-Site Scripting:** Much like an SQL Injection, a Cross-site scripting (XSS) attack also injects malicious code into a website.

Cont….

- **Cross-Site Request Forgery:** A Cross-Site Request Forgery (CSRF) attack aims to trick an authenticated user into performing an action that they do not intend to do.
- **Security Misconfiguration:** Any component of a security system that can be leveraged by attackers due to a configuration error can be considered a “Security Misconfiguration.”

Types of Vulnerabilities

- **Physical** vulnerabilities (Ex. Buildings)
- **Natural** vulnerabilities (Ex. Earthquake)
- **Hardware** and **Software** vulnerabilities (Ex. Failures)
- **Media** vulnerabilities (Ex. Disks can be stolen)
- **Communication** vulnerabilities (Ex. Wires can be tapped)

Classification of Vulnerabilities

Hardware

- Susceptibility to Humidity
- Susceptibility to Dust
- Susceptibility to Soiling
- Susceptibility to Unprotected Storage

Software

- Insufficient Testing
- Lack of Audit Trail

Network

- Unprotected Communication Lines
- Insecure Network Architecture

Classification of Vulnerabilities…

Personnel

- Inadequate recruiting process
- Inadequate security awareness

Site

- Area subject to flood
- Unreliable power source

Organizational

- Lack of regular audits
- Lack of continuity plans
- Lack of security
- Insecure network architecture

Goal of Computer Security

- The goal of computer security is to protect computer systems and the data stored within them from unauthorized access, use, disclosure, modification, or destruction.
- It encompasses various techniques, practices, and technologies to ensure the confidentiality, integrity, and availability of computer systems and their resources.

Goal of Computer Security…

- To maintain information Confidentiality.
- To ensure the Integrity and Reliability of data resources.
- To ensure the Uninterrupted Availability of data resources and online operations.
- To prevent Non-repudiation of information sent in reference to security and privacy laws and guidelines.
- To ensure Compliance with Policies and Laws regarding security and privacy

Goal of Computer Security



A. Confidentiality



- The goal of confidentiality is to ensure that only authorized individuals or systems can access and view sensitive information.
- This involves implementing measures such as encryption, access controls, and data loss prevention mechanisms to protect against unauthorized disclosure or leakage of data.

B. Integrity



- To maintain integrity, computer systems must be protected from unauthorized modification or change.
- Integrity ensures that data remains accurate, uncorrupted, and trustworthy throughout its lifecycle.
- Techniques like checksums, digital signatures, and file permissions are used to ensure the integrity of data and programs

C. Availability



- The primary goal of availability is to ensure that computer systems and resources are accessible and usable by authorized users whenever they are needed.
- Protection against denial-of-service (DoS) attacks, hardware or software failures, and network outages are vital to maintaining continuous availability (24/7/30/365)

D. Authentication



- Authentication verifies the identity of users, devices, or systems attempting to access computer resources.
- Authentication methods include username/password combinations, biometric measures (e.g., fingerprints or facial recognition), tokens, or digital certificates.
- Strong authentication methods help prevent unauthorized access.

E. Authorization



- Authorization: Once a user or entity is authenticated, authorization determines what level of access they have to specific resources or actions within a system.
- Authorization Mechanisms, including role-based access control (RBAC) and access control lists (ACLs), ensure that users are restricted to the appropriate privileges based on their roles and responsibilities.

F. Non-Repudiation



- Non-Repudiation: Non-repudiation ensures that individuals or entities cannot deny their actions or online transactions.
- Through techniques like digital signatures and audit trails, it becomes possible to prove the integrity and origin of a communication or transaction, protecting against repudiation attempts.

G. Security Awareness



- Security Awareness: Computer security also aims to raise awareness among users and organizations about potential security risks, threats, and best practices.
- Regular training, security policies, and incident response plans are necessary to foster a culture of security and promote responsible use of technology within an organization.

Cont….



- By achieving these goals, computer security helps protect individuals, organizations, and critical infrastructures from cyber threats, data breaches, unauthorized access, and other forms of harm.

Computer Security Risk

- Computer Security Risks refer to potential threats or vulnerabilities that can compromise the confidentiality, integrity, or availability of computer systems, networks, and data.
- These risks can originate from various sources, including malicious actors, software vulnerabilities, hardware failures, or human error.

- To mitigate these risks, organizations and individuals should implement security measures such as using:

✓ Using robust antivirus and anti-malware software,

✓ Regularly updating software and systems,

✓ Implementing strong access controls

✓ Implementing authentication mechanisms,

✓ Educating users about potential threats,

✓ Establishing incident response

✓ Disaster recovery plans.

Computer Security Attacks

- A computer security attack refers to an intentional or malicious act that aims to exploit vulnerabilities in computer systems, networks, or software in order to compromise their integrity, confidentiality, or availability.
- These attacks can be performed by individuals, groups, or automated programs.

Common Types of Computer Security Attacks

- ✓ Malware
- ✓ Phishing
- ✓ Denial-of-Service (DoS)
- ✓ Man-in-the-Middle (MitM)
- ✓ SQL Injection
- ✓ Cross-Site Scripting (XSS)
- ✓ Ransomware
- ✓ Password Attacks
- ✓ Social Engineering
- ✓ Zero-day Exploits

Cont….

- Malware: Malicious software, including viruses, worms, Trojans, ransomware, and spyware, is designed to contaminate/Affect computer systems and perform unauthorized actions.
- Phishing: Phishing attacks involve tricking users into exposing sensitive information, such as passwords, credit card details, or personal information, by impersonating a legitimate entity through emails, websites, or messages.

Cont…

- Denial-of-Service (DoS) Attacks: DoS attacks overwhelm (overflow) a system, network, or service with an excessive amount of traffic or requests, rendering it unavailable to legitimate users.
- Man-in-the-Middle (MitM) Attacks: In a MitM attack, an attacker intercepts and relays communication between two parties without their knowledge.
- This allows the attacker to eavesdrop, modify, or inject malicious content into the communication.

Cont…

- SQL Injection: SQL injection attacks occur when an attacker inserts malicious SQL code into a web application's database query, exploiting vulnerabilities to gain unauthorized access, retrieve sensitive data, or modify the database.
- Cross-Site Scripting (XSS): XSS attacks involve injecting malicious scripts into web pages viewed by users, allowing the attacker to execute scripts in the victim's browser and potentially steal sensitive information or perform unauthorized actions.

Cont….

- Ransomware: Ransomware is a type of malware that encrypts a victim's files or locks them out of their system until a ransom is paid.
- It can spread through email attachments, malicious downloads, or vulnerable software.
- Password Attacks: Password attacks include techniques such as brute-forcing, dictionary attacks, or password cracking to gain unauthorized access to user accounts by guessing or decrypting passwords.

Cont….

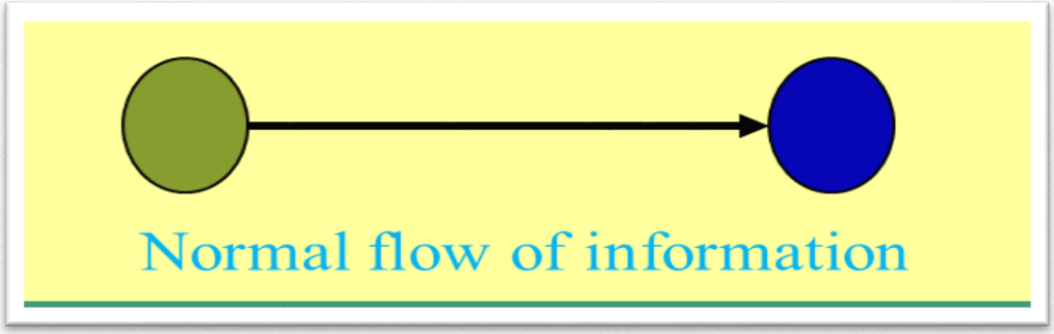
- Social Engineering: Social engineering attacks exploit human psychology and trust to manipulate individuals into revealing sensitive information, performing actions that compromise security, or granting unauthorized access.
- Zero-day Exploits: Zero-day exploits target vulnerabilities in software or systems that are unknown to the software vendor.
- Attackers exploit these vulnerabilities before a patch or fix is available, making them particularly dangerous.

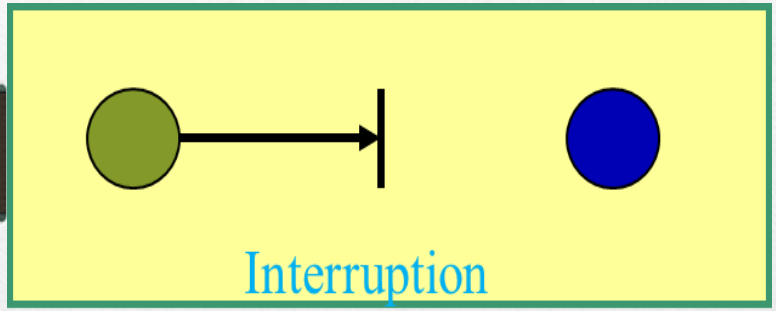
Cont…

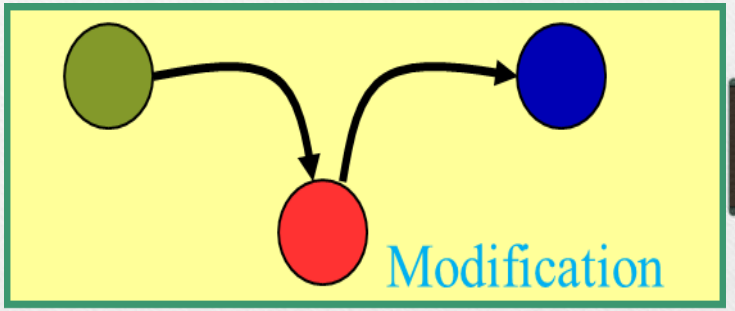
- To protect against these attacks, it is essential to implement security best practices such as using up-to-date antivirus and anti-malware software, regularly updating software and systems, employing strong authentication mechanisms, conducting security audits, raising awareness among users, and following secure coding practices.

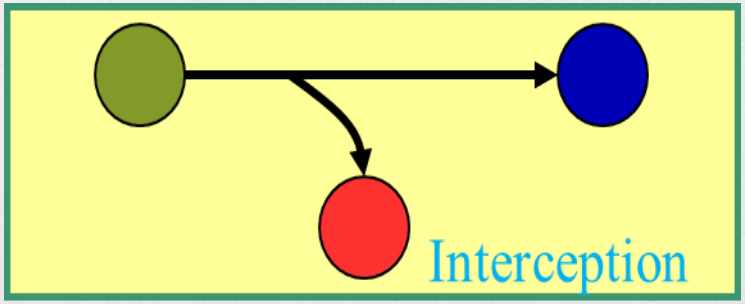
Categories of Attacks

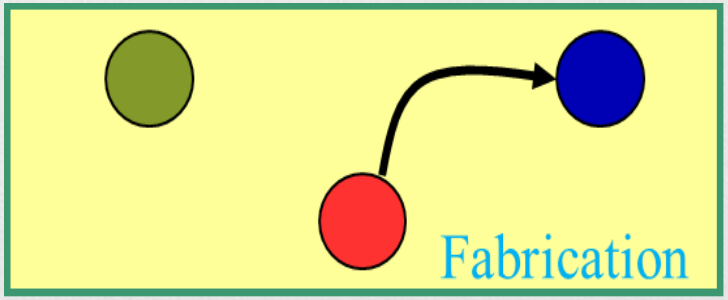
- Interruption: An attack on Availability
- Interception: An attack on Confidentiality
- Modification: An attack on Integrity
- Fabrication: An attack on Authenticity


Normal flow of information


Interruption


Modification


Interception


Fabrication

Security Policy and Mechanism

- Security Policies and Mechanisms are essential components of computer security that organizations use to protect their data, systems, and assets from various threats and vulnerabilities.
- These Policies and Mechanisms help establish a framework for managing security and ensuring that security controls are implemented effectively.

Definition of Security Policy

- Security Policies are high-level documents that outline an organization's approach to information, network and computer security.
- They set the overall objectives, principles, and guidelines for protecting sensitive information, data and computer systems assets.

Definition ……

- They define the rules, guidelines, and procedures for protecting information assets and managing security risks.
- Security Policies typically cover areas such as access control, data classification, password management, incident response, and acceptable use of resources.
- Policies should be comprehensive, clear, and aligned with industry best practices and regulatory requirements.

Types of Security Policy

There are various types of security policies, including:

- Access Control Policy: Defines who has access to what resources and under what conditions.
- Data Classification Policy: Identifies how data should be classified (e.g., public, internal, confidential) and handled accordingly.
- Acceptable Use Policy: Defines acceptable and unacceptable behaviors related to the use of organizational assets.

Cont….

- Incident Response Policy: Outlines procedures for handling security incidents and breaches.
- Password Policy: Specifies password requirements to ensure strong authentication.
- Encryption Policy: Describes when and how encryption should be used to protect computer system.

Definition of Security Mechanism

- Security Mechanisms are the technical controls, tools, and technologies implemented to enforce security policies.
- Security Mechanisms are the technical and procedural controls and safeguards that organizations implement to enforce security policies and protect against threats.
- These mechanisms are designed to Prevent, Detect, and Respond to security incidents.

Categories of Security Mechanism

These mechanisms can be categorized into various areas:

- **Access Control Mechanisms:** These include authentication methods, authorization rules, and audit trails to manage who can access what resources and what actions they can perform.
- **Encryption:** Encryption mechanisms, such as SSL/TLS for secure communication and file encryption for data at rest, protect data from unauthorized access during transmission and storage.

Cont…

- Firewalls: Firewalls are network security devices that monitor and control incoming and outgoing network traffic.
- Antivirus and Anti-Malware Software: These tools scan for and remove malicious software and threats from systems and files.
- Security Information and Event Management (SIEM): SIEM systems collect, analyze, and correlate security event data to identify potential security incidents.

Cont…

- Intrusion Detection and Prevention Systems (IDPS): IDPS Mechanisms monitor network and system activities to detect and prevent unauthorized access or malicious activities.
- Backup and Disaster Recovery: Backup mechanisms ensure the availability and integrity of data by creating regular backups.
- Employee Training and Awareness: Human-centric mechanisms focus on educating employees about security best practices and raising awareness of potential threats.
- Physical Security: Mechanisms like biometric access controls, surveillance, and locked server rooms protect physical assets and data centers.

Security Policy Enforcement

- Implementing Security Policies and Mechanisms is not enough; organizations must also ensure their effective enforcement.
- This involves ongoing monitoring, auditing, and compliance assessments to identify and address security vulnerabilities and policy violations.
- Regular security awareness training and education programs are also essential to promote a security-conscious culture and employee devotion to established policies.

Prevention, Detection, and Deterrence

- Prevention, Detection, and Deterrence are key principles in computer security that help organizations protect their systems and data from unauthorized access, attacks, and security breaches.
- These principles work together to create a layered defense strategy.

Prevention

- Prevention focuses on implementing measures and controls to proactively prevent security incidents from occurring.
- The goal is to minimize vulnerabilities and reduce the attack surface.
- Key preventive measures include: access control, patch management, secure configuration, network segmentation, secure coding practices and security awareness training.

Detection

- Detection involves monitoring systems, networks, and activities to identify potential security incidents and breaches.
- The objective is to detect anomalies, suspicious behavior, or indicators of compromise.
- Key detection measures include: Intrusion Detection Systems (IDS), Security Information and Event Management (SIEM), Log Monitoring and Analysis, Endpoint Protection and Threat Intelligence.

Deterrence

- Deterrence aims to discourage potential attackers by implementing deterrent controls and demonstrating a strong security posture.
- The goal is to make it more difficult and less attractive for attackers to target an organization.
- Key deterrence measures include: Security Policies and Procedures, Physical Security, Security Audits and Assessments, Incident Response Planning and Security Governance.

Cont…

- By combining prevention, detection, and deterrence strategies, organizations can enhance their overall security posture and mitigate the risks associated with cyber threats.
- It's important to regularly review and update security measures to stay resilient against evolving threats and emerging attack techniques.

Software Security Assurance

- Software Security Assurance refers to the practices and processes employed to ensure that software systems are developed, deployed, and maintained in a secure manner.
- It involves integrating security considerations throughout the entire software development life cycle (SDLC) to minimize vulnerabilities and protect against potential attacks.

Software Security Assurance Mechanism

- Secure Software Development Life Cycle: Implementing a secure SDLC involves incorporating security practices at each stage of the software development process.
- This includes requirements gathering, design, coding, testing, deployment, and maintenance.

Cont…

- Secure Coding Practices: Developers should follow secure coding practices to minimize vulnerabilities.
- This includes guidelines such as input validation, output encoding, proper error handling, secure session management, and secure use of cryptography.
- Adhering to secure coding standards, such as the OWASP Top Ten, can help mitigate common security risks.

Cont…

- Threat Modeling: Conducting threat modeling helps identify potential security threats and vulnerabilities early in the development process.
- It involves analyzing the software architecture, identifying potential attack vectors, and assessing the impact and likelihood of threats.
- This information can guide the implementation of appropriate security controls.

Cont….

- Security Testing: Comprehensive security testing is essential to identify and address vulnerabilities and weaknesses in software systems.
- This includes various types of testing such as penetration testing, vulnerability scanning, code review, and security-focused unit testing.
- Automated tools and manual testing techniques should be used to uncover potential security flaws.

Cont….

- Secure Deployment and Configuration: Properly configuring and securing the deployment environment is crucial for software security.
- This includes hardening servers, applying security patches, configuring firewalls, using secure network protocols, and implementing secure communication channels.
- Additionally, securely managing access credentials and permissions is vital to prevent unauthorized access.

Cont…

- Security Incident Response: Establishing an incident response plan enables organizations to respond effectively to security incidents.
- The plan should define the steps to be taken in the event of a security breach, including incident detection, containment, eradication, and recovery.
- Regularly testing the incident response plan through simulations and exercises helps ensure its effectiveness.

Cont…

- Security Training and Awareness: Promoting security awareness and providing training to software developers, testers, and other stakeholders is crucial.
- Educating the development team about secure coding practices, common vulnerabilities, and security risks helps foster a security-conscious mindset and encourages adherence to secure development practices.

Cont…

- Ongoing Maintenance and Updates: Software systems should be regularly maintained and updated to address newly discovered vulnerabilities and security patches.
- Applying security updates promptly and managing dependencies reduces the risk of exploitation.
- Additionally, monitoring and logging mechanisms should be in place to detect and respond to security incidents.

Cont…

- Compliance and Regulatory Considerations: Organizations should consider relevant compliance requirements and industry-specific regulations when implementing software security assurance measures.
- Compliance with standards such as the Payment Card Industry Data Security Standard (PCI DSS) or General Data Protection Regulation (GDPR) may necessitate specific security controls and practices.

Cont…

- By incorporating software security assurance practices, organizations can reduce the risk of security breaches, protect sensitive data, and ensure the integrity and availability of their software systems.
- It is an ongoing process that requires continuous improvement and adaptation to emerging threats and vulnerabilities.

Summary

- Computer security refers to the protection of computer systems, networks, and data from unauthorized access, use, disclosure, disruption, or destruction.
- It involves implementing measures and practices to prevent, detect, and respond to various security threats and risks.


Thank You